

G-CAF

GovDigital Composable Architecture Framework

Volume 18

Vendor Compliance & Certification

v2.0

Table of Contents

Chapter 1 88 Compliance Requirements

Consolidated from Security, Data, Integration, Operations contracts + DGE IT requirements

Chapter 2 4 Compliance Tiers

Mandatory (pre-contract), Required (6 months), Recommended (12 months), Conditional

Chapter 3 3-Level Certification Process

Registered, Certified, Preferred — with 4-phase journey

Chapter 4 Compliance Roadmap

Week-by-week pre-contract + month-by-month post-contract timeline

Chapter 5 Certification Maintenance

Ongoing obligations, change notifications, renewal process

Chapter 6 Exception Process

Eligibility by tier, request requirements, review timeline

Chapter 7 Suspension & Revocation

Grounds, process, effects, appeals, and reinstatement

Chapter 8 Vendor Exit Strategy

Alternate supplier requirements by PBC criticality, exit planning

Chapter 9 Contract Signatures & Templates

Signature blocks, self-assessment form, compliance checklist, attestation letter

Chapter 1

88 Compliance Requirements

All G-CAF requirements applicable to vendors, consolidated from standard contracts and DGE IT Technical Requirements. No duplication — existing contract requirements are referenced, not copied.

Category	Source	Count	Tier 1	Tier 2	Tier 3
Security	Security Contract v2.0	28	15	10	3
Data Handling	Data Contract v2.1	15	8	5	2
Integration	Integration Contract v1.1	12	5	5	2
Operations	Operations Contract v1.2	10	4	4	2
Sovereign Cloud	DGE REQ-ARC-045-049	5	5	0	0
DevSecOps	DGE REQ-SEC-060-065	6	2	4	0
Third-Party Risk	DGE REQ-SEC-085-093	12	4	6	2
Total		88	43	34	11

Security Requirements Highlights

ID	Requirement	Tier
SEC-01	MFA for all privileged access; SAML 2.0/OIDC; strong passwords; account lockout	1
SEC-02	RBAC; least privilege; segregation of duties; quarterly access reviews	1–2
SEC-03	AES-256 at rest; TLS 1.3 in transit; certificate management; key rotation	1
SEC-04	SIEM integration; security event logging; 12-month log retention	1–2
SEC-05	Annual penetration testing; SAST/DAST; vulnerability patching (critical <24h)	1–2

Chapter 2

4 Compliance Tiers

Tier	Name	Definition	Timeline	Certification Impact
Tier 1	Mandatory	Must comply before contract award	Pre-contract	Blocker — no certification without
Tier 2	Required	Must comply within 6 months of contract award	6 months	Required for certification renewal
Tier 3	Recommended	Should comply, best practice	12 months	Improves certification level
Tier 4	Conditional	Required only for specific contexts	Context-dependent	Required when context applies

Tier 1 criteria: data sovereignty (UAE hosting), critical security controls (MFA, encryption), legal/regulatory requirements, incident notification, core certifications. Tier 2: enhanced security, operational readiness, integration standards, monitoring. Tier 3: advanced automation, best practices. Tier 4: AI-specific requirements, industry-specific controls.

Chapter 3

3-Level Certification Process

Certification Levels

Level	Name	Requirements	Validity	Benefits
Level 1	Registered	Tier 1 complete, 50% Tier 2	1 year	Eligible for contracts
Level 2	Certified	Tier 1+2 complete, 50% Tier 3	2 years	Preferred vendor status
Level 3	Preferred	Tier 1+2+3 (80%), proven track record	3 years	Strategic partner benefits

4-Phase Certification Journey

Phase	Duration	Activities
1. Preparation	2–4 weeks	Learn G-CAF requirements, self-assess against 88 requirements, plan remediation, implement q
2. Application	1–2 weeks	Submit application, provide evidence package, pay certification fee
3. Review	2–4 weeks	Document review → Technical review → Audit (Level 2+) → Decision
4. Outcome	—	Approved (certificate issued) / Conditional (30-day remediation) / Rejected (reasons provided)

Chapter 4

Compliance Roadmap

Pre-Contract Phase (Weeks 1–12) — Focus: Tier 1

Weeks	Focus	Key Activities
1–2	Assessment	Gap analysis against 88 requirements; current state review
3–4	Quick Fixes	Password policy, account lockout, basic logging configuration
5–6	Security Controls	MFA implementation, encryption, SIEM integration
7–8	Hosting	UAE migration (if needed), data residency verification
9–10	Integration	API Gateway registration, OAuth 2.0, API documentation (OpenAPI)
11–12	Certification	Level 1 application, evidence package submission

Post-Contract Phase (Months 1–6) — Focus: Tier 2

Months	Focus	Key Activities
1–2	Security Enhancements	HSM setup, managed identities, first access review
3–4	DevSecOps	DAST implementation, container scanning, IaC scanning
5–6	Operations	Monitoring setup, dashboards, multi-AZ deployment

Continuous Improvement (Months 6–12) — Focus: Tier 3: Q3 advanced monitoring (anomaly detection, distributed tracing), Q4 maturity (event-driven integration, data lineage, BCP testing).

Chapter 5

Certification Maintenance

Ongoing Obligations

Obligation	Frequency	Evidence Required
Maintain controls	Continuous	Audit trail, logs
Report incidents	As they occur	Incident reports (within 4 hours)
Annual attestation	Yearly	Signed attestation letter
Notify changes	Within 30 days	Change notification form
Security scanning	Monthly	Scan reports
Access reviews	Quarterly	Review documentation
BCM/DR exercises (Level 2+, Critical BCs)	Annually	Exercise participation record

Change Notifications Required

Change Type	Advance Notice	DDA Approval?
Major version upgrade	30 days	No
Architecture change	30 days	Yes — DDA review
Hosting change	30 days	Yes
Ownership change	Immediately	Re-certification may be required
Security incident	Within 4 hours	No
New subcontractor	30 days	Yes
Data flow change	30 days	Yes — DDA review

Renewal: 90 days before expiry reminder → 60 days submit renewal + evidence → 30 days review complete → expiry date new certificate issued.

Chapter 6

Exception Process

Tier	Exception Allowed?	Approver	Notes
Tier 1	Rarely	ARB	Strong justification; only for technical impossibility
Tier 2	Timeline extension only	DDA	Extension of deadline, not waiver of requirement
Tier 3	Generally flexible	Project Team	Document rationale for non-implementation
Tier 4	N/A	DDA	Contextual; applicability determined case-by-case

All exception requests must include: Requirement ID, Justification, Risk Assessment, Compensating Controls, Timeline to compliance, Business Impact. Review timeline: 10–15 business days total (3 days initial review → 5 days risk assessment → 5 days escalation → 2 days decision).

Chapter 7

Suspension & Revocation

Grounds for Suspension

Reason	Action	Remediation Period
Major security incident	Immediate suspension	Pending investigation
Non-compliance discovered	Notice + suspension	30 days
Failed to report changes	Warning, then suspension	15 days
Non-payment of fees	Grace period, then suspension	30 days
Failed audit	Notice + suspension	30 days
Subcontractor non-compliance	Warning, then suspension	30 days

During suspension: vendor remains in registry as "Suspended", cannot bid on new contracts, existing contracts continue at customer discretion, all compliance obligations continue, suspension visible to all government entities.

Revocation: permanent removal from G-CAF registry. Requires ARB approval. Grounds: repeated suspension, fraud/misrepresentation, fundamental breach, refusal to remediate. Appeal available within 30 days to ARB.

Chapter 8

Vendor Exit Strategy

Applies to all PBCs sourced as Buy or Outsource. Aligns with UAE TPSP requirements.

Alternate Supplier Requirements by PBC Criticality

Criticality	Requirement	Activation Timeline	Review
Critical	Pre-qualified alternate on standby; activation within 30 days	Within 30 days	Semi-annual
High	Alternate identified and security-assessed (not necessarily contracted)	Within 60 days	Annual
Medium	Alternate sourcing strategy documented; market scan completed	Within 90 days	At contract renewal
Low	No formal alternate requirement	Best effort	—

Alternate suppliers must complete the same Vendor Security Assessment Questionnaire. Critical PBC alternates must hold G-CAF Certification Level 1+. All alternates tracked in PBC Catalog (Alternate Supplier field).

Exit planning includes: data return/destruction procedures, knowledge transfer timeline, transition support period, IP and code escrow provisions, and service continuity during handover.

Chapter 9

Contract Signatures & Templates

Standard signature blocks for all vendor compliance contracts include three parties: Vendor (company details + authorized representative), Customer Entity (entity details + authorized representative), and DDA Witness (name, title, date, signature).

Template Suite

Template	Purpose	Used By
Vendor Contract	Formal vendor obligations covering all 88 requirements	Legal / Procurement
Self-Assessment Form	Vendor self-evaluates against 88 requirements pre-application	Application Compliance Lead
Compliance Checklist	Audit verification checklist for DDA reviewers	DDA / Auditors
Attestation Letter	Formal annual compliance attestation signed by vendor executive	Vendor Executive

Department of Government Enablement (DGE) | Abu Dhabi
Enterprise Architecture Office | govdigital.ea@dge.gov.ae